Team Relay

Sprint #2 Review

Yun Waddy Oo, Shannon Curtis, Don Shin, Yanitsa Ivanova

October 7 2026

Sprint Goals



- CRUD for fEMR clients
- CRUD for fEMR admins
- Database Schema
- Encryption
- Licensing
- Unique ID Generation

Sprint #2 Backlog

~~FGS-26~~ Research CRUD for fEMR admin	yivanova	scurti03
~~FGS-25~~ Research CRUD for fEMR Clients	dshin17	dshin17
~~FGS-29~~ Research how fEMR currently deals with m...	dshin17	dshin17
~~FGS-30~~ Find and look into fEMR's AWS and related ...	dshin17	dshin17
~~FGS-31~~ Explore repo for directories/files for managi...	dshin17	dshin17
~~FGS-32~~ Progress on defining client info and how to ...	dshin17	dshin17
~~FGS-28~~ Data Schema	yuoo	scurti03
~~FGS-24~~ Encryption	scurti03	scurti03
~~FGS-23~~ Unique KitID	scurti03	scurti03

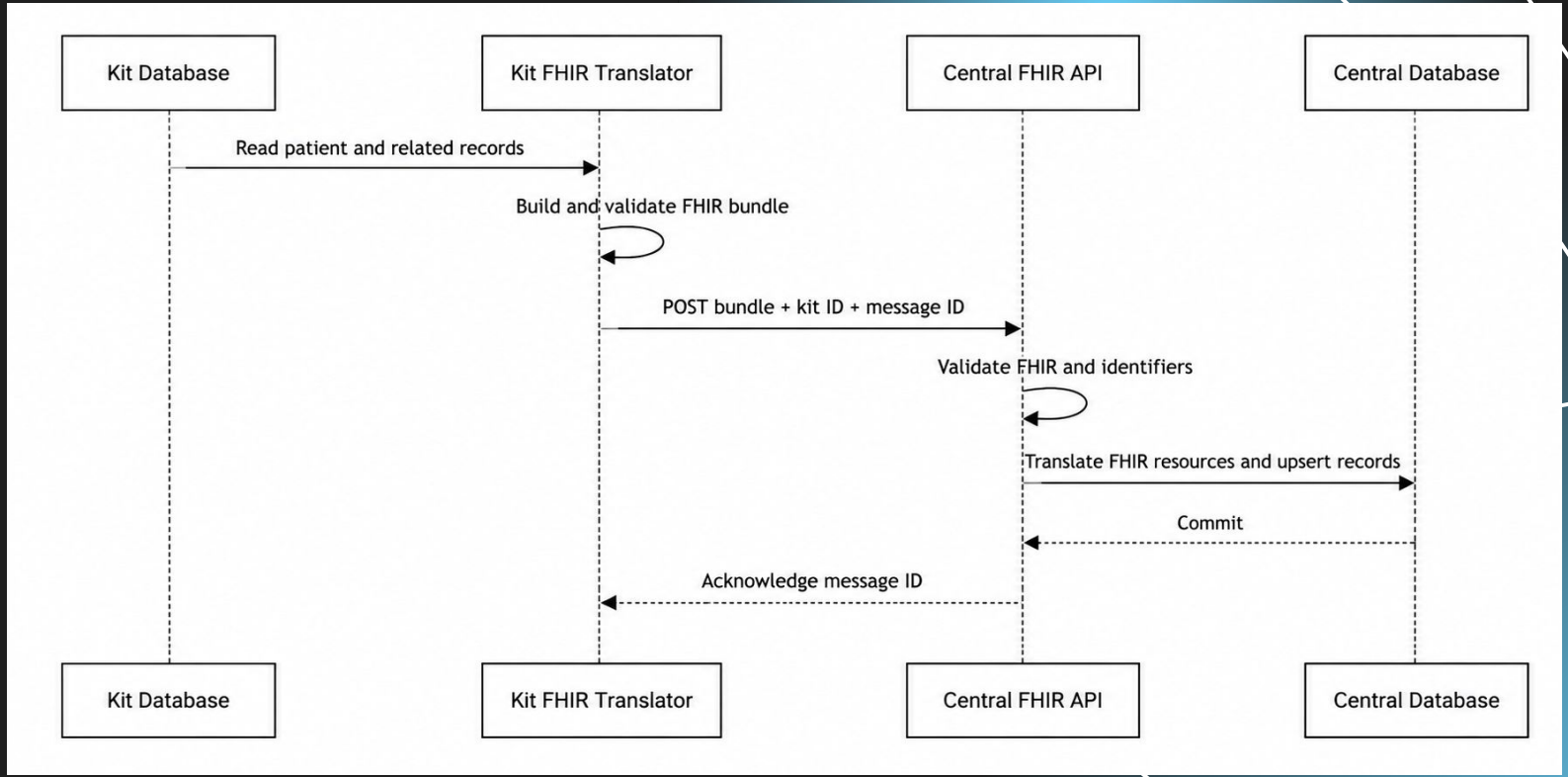
CRUD for User + Organization

- Exists declaration of classes for user and organization, undefined
- Under views, requests exists to fetch all users, create a user while validating requests with serializer, empty for organizations
- Similar to users, splitting organization_view for handling GET and POST
- single_view for GET, PUT, and DELETE

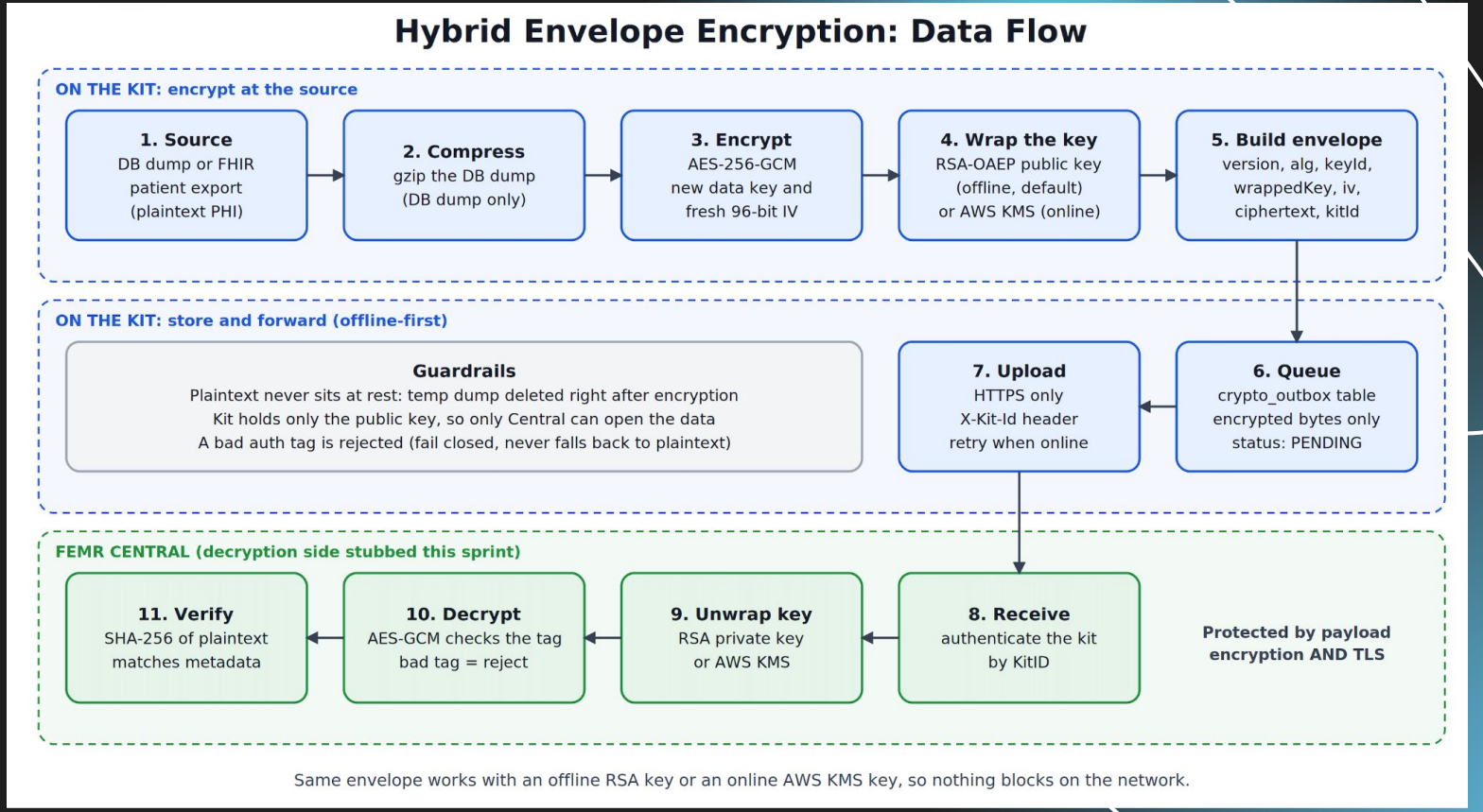
Current Play Repository Findings: Tables

Domain	Tables	Migration-derived table names
Identity & migration control	5	play_evolutions; users; roles; user_roles; login_attempts
Clinical encounter core	13	patients; photos; patient_encounters; patient_encounter_photos; vitals; patient_encounter_vitals; patient_age_classifications; chief_complaints; tabs; tab_fields; tab_field_types; tab_field_sizes; patient_encounter_tab_fields
Pharmacy & medication	15	medications; medication_generics; medication_generic_strengths; medication_medication_generic_strengths; medication_inventories; concept_medications; concept_medication_forms; concept_medication_units; concept_medication_generics; concept_medication_generic_strengths; concept_medication_concept_generic_strengths; concept_prescription_administrations; patient_prescriptions; patient_prescription_replacements; patient_prescription_replacement_reasons
Diagnosis & WHO reporting	4	concept_diagnoses; concept_who_health_events; concept_who_procedures; who_report_config
Mission deployment	5	mission_countries; mission_cities; mission_teams; mission_trips; mission_trip_users
Operations & status	6	system_settings; network_status; internet_status; kit_status; database_status; feedback
Reference & localization	6	language_codes; measurement_categories; measurement_units; pages; page_elements; page_element_translations

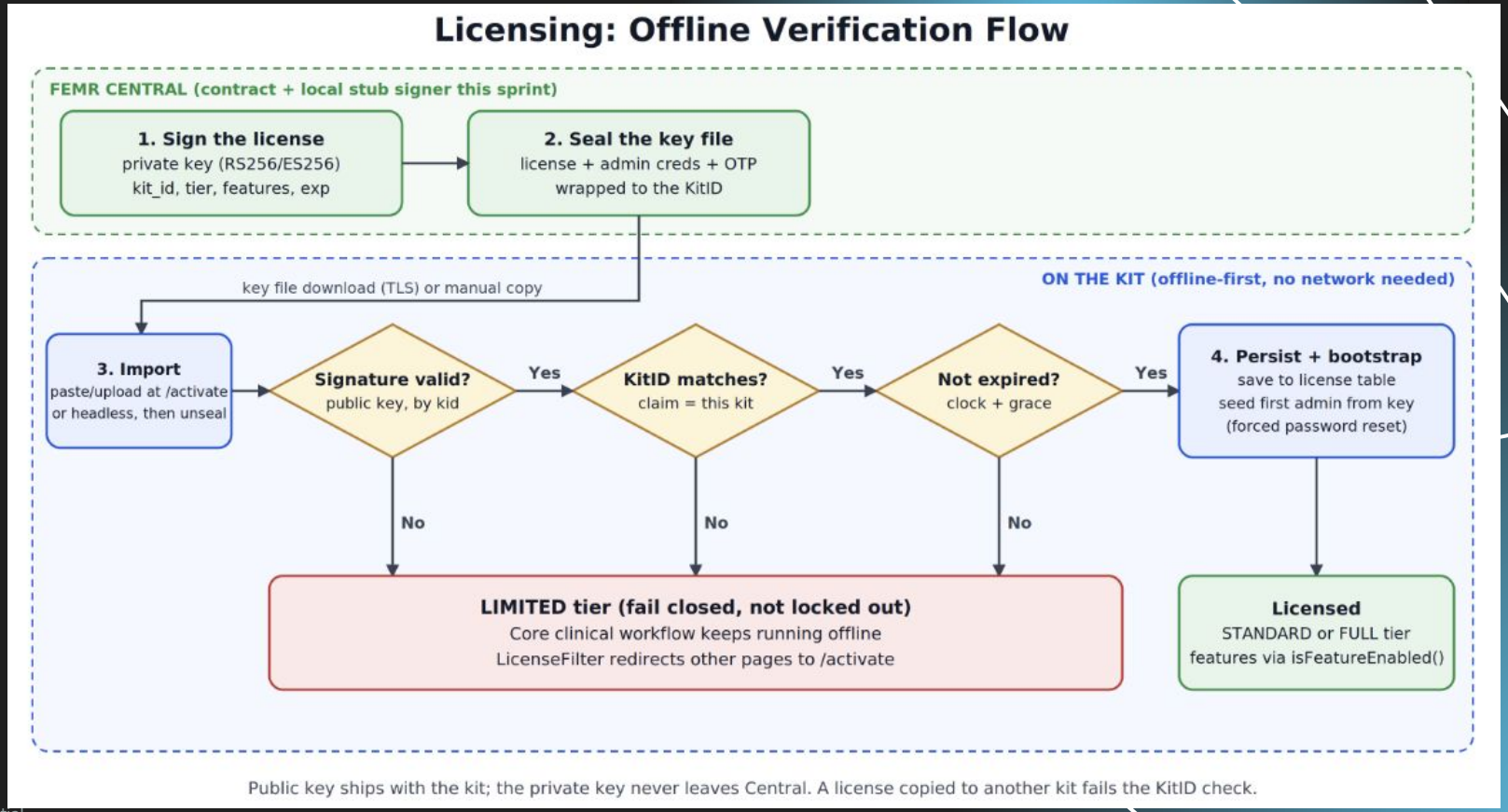
Database Migration to Central



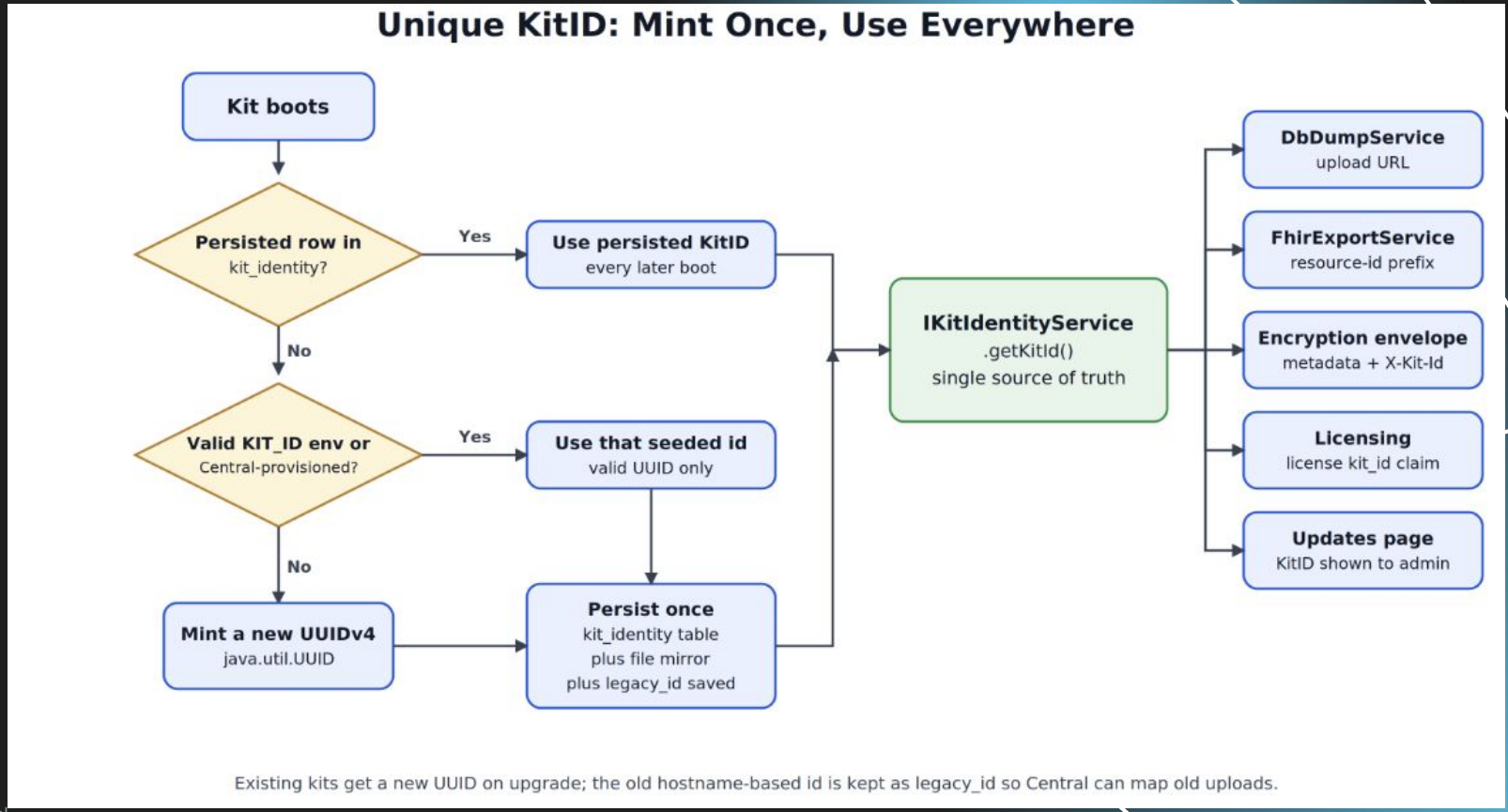
Encryption


Hybrid Envelope Encryption: Data Flow
ON THE KIT: encrypt at the source
1. Source
DB dump or FHIR patient export (plaintext PHI)
2. Compress
gzip the DB dump (DB dump only)
3. Encrypt
AES-256-GCM new data key and fresh 96-bit IV
4. Wrap the key
RSA-OAEP public key (offline, default) or AWS KMS (online)
5. Build envelope
version, alg, keyId, wrappedKey, iv, ciphertext, kitId
ON THE KIT: store and forward (offline-first)
Guardrails
Plaintext never sits at rest: temp dump deleted right after encryption
Kit holds only the public key, so only Central can open the data
A bad auth tag is rejected (fail closed, never falls back to plaintext)
7. Upload
HTTPS only
X-Kit-Id header
retry when online
6. Queue
crypto_outbox table
encrypted bytes only
status: PENDING
FEMR CENTRAL (decryption side stubbed this sprint)
11. Verify
SHA-256 of plaintext matches metadata
10. Decrypt
AES-GCM checks the tag
bad tag = reject
9. Unwrap key
RSA private key or AWS KMS
8. Receive
authenticate the kit by KitID
Protected by payload encryption AND TLS
Same envelope works with an offline RSA key or an online AWS KMS key, so nothing blocks on the network.

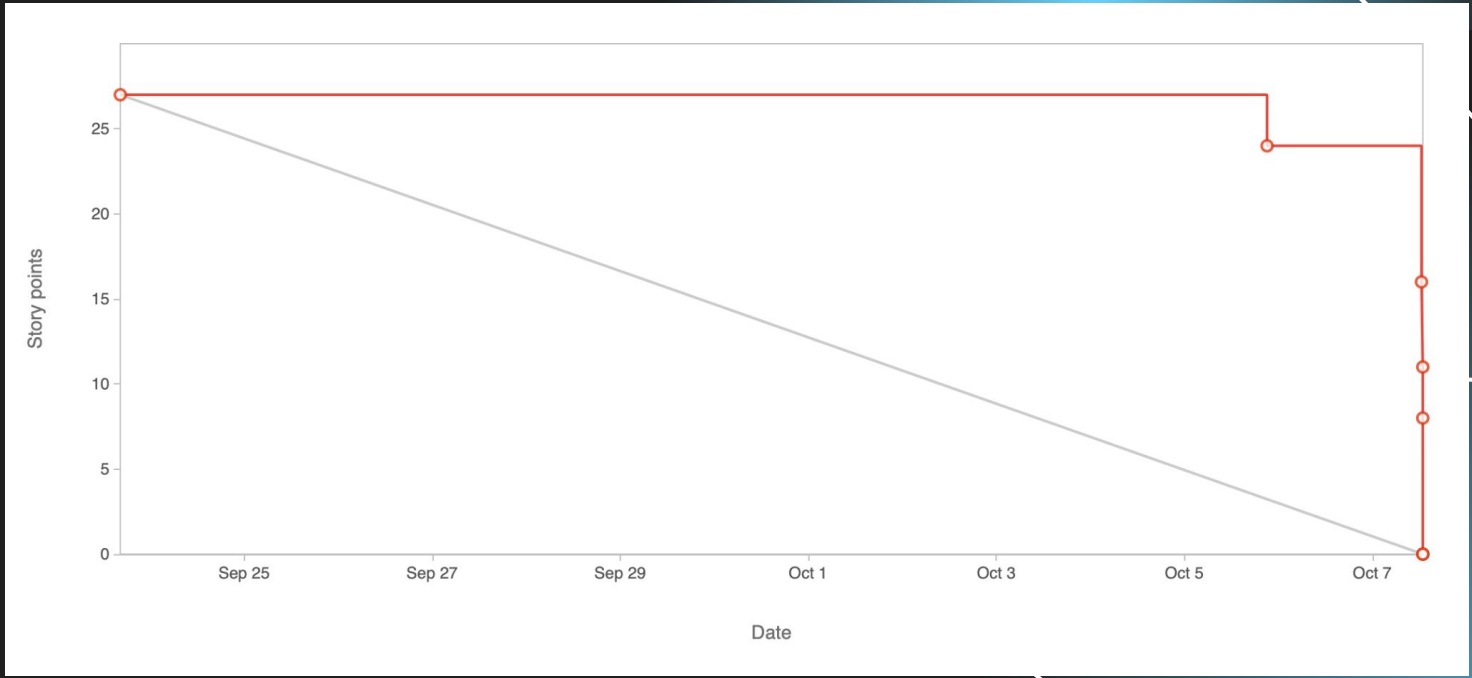
Licensing


Licensing: Offline Verification Flow
FEMR CENTRAL (contract + local stub signer this sprint)
1. Sign the license
private key (RS256/ES256)
kit_id, tier, features, exp
2. Seal the key file
license + admin creds + OTP
wrapped to the KitID
key file download (TLS) or manual copy
ON THE KIT (offline-first, no network needed)
3. Import
paste/upload at /activate
or headless, then unseal
Signature valid?
public key, by kid
Yes
KitID matches?
claim = this kit
Yes
Not expired?
clock + grace
Yes
4. Persist + bootstrap
save to license table
seed first admin from key
(forced password reset)
No
No
No
LIMITED tier (fail closed, not locked out)
Core clinical workflow keeps running offline
LicenseFilter redirects other pages to /activate
Licensed
STANDARD or FULL tier
features via isFeatureEnabled()
Public key ships with the kit; the private key never leaves Central. A license copied to another kit fails the KitID check.

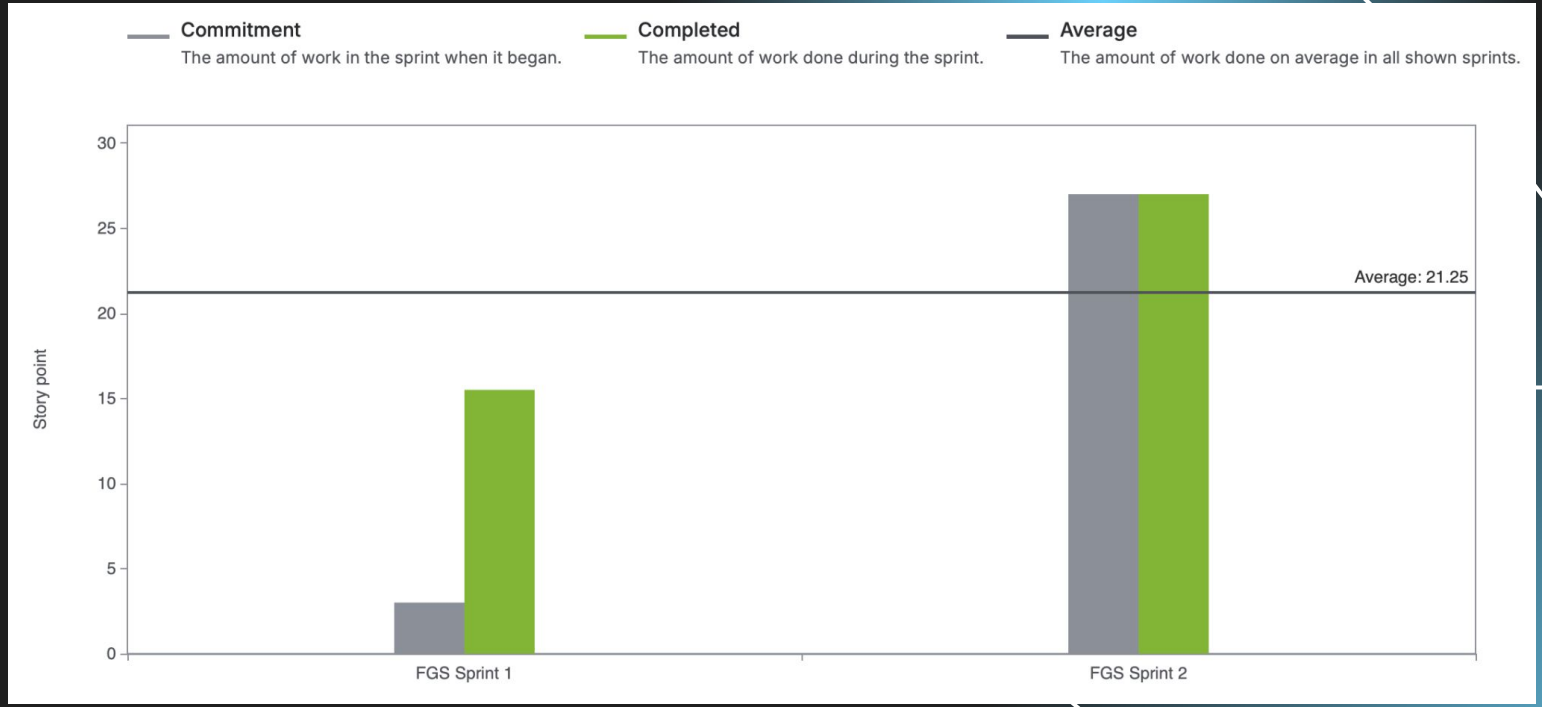
KitID


Unique KitID: Mint Once, Use Everywhere
Kit boots
Persisted row in kit_identity?
Yes
Use persisted KitID every later boot
No
Valid KIT_ID env or Central-provisioned?
Yes
Use that seeded id valid UUID only
No
Mint a new UUIDv4 java.util.UUID
Persist once kit_identity table plus file mirror plus legacy_id saved
IKitIdentityService .getKitId() single source of truth
DbDumpService upload URL
FhirExportService resource-id prefix
Encryption envelope metadata + X-Kit-Id
Licensing license kit_id claim
Updates page KitID shown to admin
Existing kits get a new UUID on upgrade; the old hostname-based id is kept as legacy_id so Central can map old uploads.

Burndown Chart



Velocity Chart



Retrospective

▶️ Start doing	🛑 Stop doing	🙌 Keep doing
Upload the finding reports on Confluence/Slack	Finishing Presentation Slides right before the meeting	
Utilize Jira better		
Better Communication/ Weekly Standup		

Next steps

Step 1

Implement the encryption envelope to prepare for direct dumps into central bypassing current use of s3 buckets.

Step 2

Ensure all kits have unique KitID's and begin implementation licensing handshake and key file.

Step 3

Implement CRUD endpoints for organization, update CRUD implementation for users to update and disable

Thank you!

Questions?